Static Analysis in Practice

We acknowledge funding provided by Microelectronic Commons and the support of OUSW(R&E).

Static Analysis on IoT device

- Offensive/Red teaming -> You get the device.
- Defensive -> Source Code.

Red teaming

- Acquire firmware.
- Have a list of common classes of bugs for the target firmware.
- Identify the tools => Run => Refine => Run.

Firmware Acquisition

Firmware Acquisition

- Download from vendor website: https://support.netgear.com/support/product/r7800
- Extract from companion apps.
- Hijack upgrade.
- Extract from device.

Extracting from Companion Apps

Play in February 2020 as our dataset. We further selected those using BLE by scanning relevant APIs such as `startScan`, and ultimately obtained 135, 486 apps in total. From these BLE apps, we directly unpacked the APKs and extracted the Nordic and TI firmware, since they have distinct signatures, which can be easily distinguished (*e.g.*, magic bytes in the firmware header). Ultimately, we successfully obtained 793 such unique bare-metal firmware (768 from Nordic and 25 from TI). Note that one app may contain multiple firmware

https://github.com/OSUSecLab/FirmXRay/tree/master/dataset

As shown in the figure, *EXT-DS* includes way more confirmed images than *OTA-DS* (6,862 vs 1,570). We attribute this to two reasons. First, to reduce the cost of maintaining an OTA server, device manufacturers tend to choose bundling firmware within the APKs and rely on Google Play Store to distribute firmware. Second, *OTACap* suffers from the inher-

Extracting from Companion Apps

Play in February 2020 as our dataset. We further selected those using BLE by scanning relevant APIs such as `startScan`, and ultimately obtained 135, 486 apps in total. From these BLE apps, we directly unpacked the APKs and extracted the Nordic and TI firmware, since they have distinct signatures, which can be easily distinguished (*e.g.*, magic bytes in the firmware header). Ultimately, we successfully obtained 793 such unique bare-metal firmware (768 from Nordic and 25 from TI). Note that one app may contain multiple firmware

Do not store firmware in companion Apps

https://github.com/OSUSecLab/FirmXRay/tree/master/dataset

As shown in the figure, *EXT-DS* includes way more confirmed images than *OTA-DS* (6,862 vs 1,570). We attribute this to two reasons. First, to reduce the cost of maintaining an OTA server, device manufacturers tend to choose bundling firmware within the APKs and rely on Google Play Store to distribute firmware. Second, *OTACap* suffers from the inher-

Hijack Upgrade

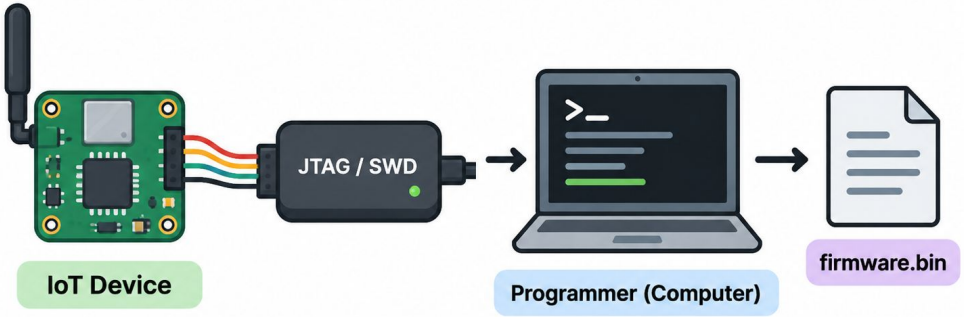
> Ideally, firmware download should be protected via the unique topic names to subscribe to or additional authentication [76]. However, we found 3 MQTT endpoints that allowed us to connect to the wildcard topic # without any authentication, returning trunks of firmware data or the real firmware distribution points. Additionally, one developer used the test broker Mosquitto [23] to send OTA URLs.

Do not distribute the firmware in plain.

Extract from Device

Disable JTAG/On-device debugging!

- JTAG (Joint Test Action Group) Support.
- Open the device: Identify the JTAG pins. Can be automated with JTAGulator
- J-Link, ST-Link => Connect to the appropriate pins.
- Dump flash using openocd.



Identify Common classes of Bugs

- Memory corruption vulnerabilities.
- Weak authentication, weak cryptographic primitives.
- Backdoors.
- Information leakage --- debug logs!

Incorrect Cryptographic Primitives Uses

Authentication Weakness: Fixed default password/ weak password / superuser access.

Mirai Botnet (almost) took down the entire internet.

> "Mirai isn't really a fancy piece of malware, but it's effective and spreads quickly because it targets Internet of Things (IoT) devices that are extremely easy to hack. These devices, mostly DVRs and surveillance cameras, use default and predictable passwords, such asadmin and *123456*,*root* and *password*, or *guest* and *guest*, among others," says **Lorenzo Franceschi-Bicchierai** at Motherboard.

Incorrect Cryptographic Primitives Uses

Fixed/weak keys, Incorrect implementation.

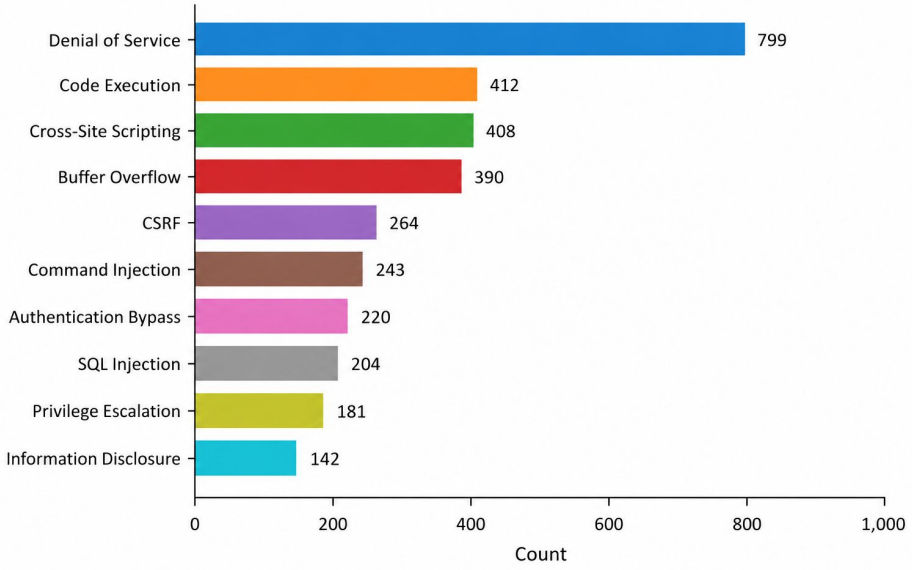
Hardcoded AES 256 bit key used in Kankun IoT/Smart socket and its mobile App

---

Security Advisory on Improper Certificate Validation in TP-Link Tapo H100 and P100 Allows Man-in-the-Middle Attack

A Use of Password Hash Instead of Password for Authentication issue was discovered in Dahua DH-IPC-HDBW23A0RN-ZS, DH-IPC-HDBW13A0SN, DH-IPC-HDW1XXX, DH-IPC-HDW2XXX, DH-IPC-HDW4XXX, DH-IPC-HFW1XXX, DH-IPC-HFW2XXX, DH-IPC-HFW4XXX, DH-SD6CXX, DH-NVR1XXX, DH-HCVR4XXX, DH-HCVR5XXX, DHI-HCVR51A04HE-S3, DHI-HCVR51A08HE-S3, and DHI-HCVR58A32S-S2 devices. The use of password hash instead of password for authentication vulnerability was identified, which could allow a malicious user to bypass authentication without obtaining the actual password.

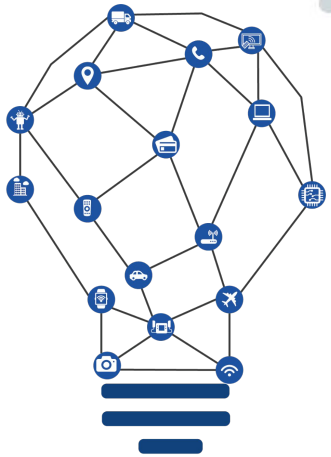
Distribution of Vulnerability Classes



https://vtechworks.lib.vt.edu/server/api/core/bitstreams/f92e51e8-5930-4fab-9a96-3c072c8c3c51/content

Catalog/practice exercises for common classes of IoT bugs

https://github.com/OWASP/IoTGoat



IoTGoat

OWASP

Use the tools on the extracted firmware

KARONTE: https://github.com/ucsb-seclab/karonte/tree/master

FirmRec: https://github.com/seclab-fudan/FirmRec/tree/main

EmTaint: https://dl.acm.org/doi/10.1145/3597926.3598062

FirmXRay: https://github.com/OSUSecLab/FirmXRay